

НАЦІОНАЛЬНИЙ УНІВЕРСИТЕТ БІОРЕСУРСІВ ТА ПРИРОДОКОРИСТУВАННЯ

Кафедра комп'ютерних систем, мереж та кібербезпеки

ЗВІТ ДО ПРАКТИЧНОЇ РОБОТИ №11

“ Визначення типу та рівня гарантування послуг безпеки
функціонального профіля захищеності КМ”

Виконав: студент(ка) групи: КІБ-230116
Лукашенко-Аветісян Руслан

Київ 2025

Тема: “Визначення типу та рівня гарантування послуг безпеки функціонального профіля захищеності КМ”

Хід роботи

1. Визначити клас та підклас АС підприємства, яка адмініструється ОС Windows Server.

Інформаційна система підприємства (підприємство з виготовлення БПЛА) **відноситься до класу 2** — *локалізований багатомашинний багатокористувачевий комплекс*, оскільки організаційна структура реалізована у вигляді кількох дочірніх доменів в Active Directory (Security.department.ruslan.com.ua, IT.ruslan.com.ua, HR-department.ruslan.com.ua), об'єднаних у єдину централізовану систему управління. У цій системі реалізовано механізми розмежування доступу шляхом використання ролей (адміністратори та звичайні користувачі) та груп доступу (FULL_ACCESS, ONLY_VIEW), що дозволяє одночасно обробляти інформацію з різними рівнями обмеження доступу в межах єдиного технічного середовища.

Підсистема також належить до підкласу з підвищеними вимогами до конфіденційності та доступності (КД), оскільки підприємство працює з критично важливою технічною та військовою інформацією, включаючи проєктну документацію, технічні характеристики БПЛА, а також персональні дані працівників. Конфіденційність цієї інформації є ключовою для безпеки держави та конкурентоспроможності підприємства. Водночас, забезпечення високого рівня доступності — обов'язкова умова для безперебійної роботи виробничих, сервісних і дослідницьких процесів. Це підтверджується використанням резервованих систем зберігання даних (RAID 1), корпоративного поштового сервера (Exchange Server 2013) та централізованих служб мережевої інфраструктури (DHCP), що гарантує відмовостійкість і постійний доступ до критичних ресурсів.

2. Обрати стандартний функціональний профіль захищеності

Враховуючи, що підприємство обробляє критичну військову та науково-технічну інформацію в умовах багатокористувацького середовища з розмежуванням доступу, було обрано **стандартний функціональний профіль захищеності 2.КД.3 { КД-3, КА-3, КО-1, КК-1, ДР-3, ДС-2, ДЗ-2, ДВ-2, НР-4, НИ-2, НК-1, НО-3, НЦ-3, НТ-2 }**. Цей профіль забезпечує максимальний захист **конфіденційності та доступності**, відповідає **класу 2** автоматизованої системи з підвищеними вимогами до захисту, та **максимально охоплюється вбудованими механізмами захисту Windows Server**, що дозволяє ефективно реалізувати вимоги без потреби у значних доопрацюваннях.

3. Здійснити класифікацію вказаних в стандартному обраному з НД ТЗІ 2.5-005-99 послуг безпеки. Відповідно до призначення послуги вказати методи та засоби Windows Server, за допомогою яких дану послугу було реалізовано.

КД-3 — Довірча конфіденційність

Ця послуга гарантує, що конфіденційна інформація зберігається у зашифрованому вигляді й доступна лише авторизованим особам. У Windows Server її реалізовано за допомогою **BitLocker, EFS (Encrypting File System)** та **прав доступу NTFS (ACL)**. Це дозволяє як шифрувати вміст, так і визначати, хто саме має до нього доступ, що відповідає вимогам довірчої конфіденційності.

КА-3 — Адміністративна конфіденційність

Забезпечує централізоване керування доступом до інформації на рівні ролей і повноважень.

У Windows Server це досягається через **Active Directory, GPO** та механізми

розмежування прав доступу (RBAC, Delegation of Control). Завдяки цьому адміністратор може точно регламентувати, хто має доступ до яких об'єктів.

КО-1 — Повторне використання об'єктів

Спрямована на запобігання витоку інформації при повторному використанні ресурсів (файлів, пам'яті, принтерів тощо). У Windows Server реалізується через **очищення PageFile при вимкненні системи**, використання **скриптів очищення тимчасових даних**, а також **додатків типу sdelete**. Це дозволяє уникнути залишків чутливої інформації в системі.

КК-1 — Аналіз прихованих каналів

Забезпечує виявлення потенційних каналів витоку інформації, які використовують **побічні або непрямі методи**. У Windows Server це частково реалізується через **аудит незвичних мережевих дій, жорстке налаштування міжпроцесної взаємодії та GPO з обмеженнями доступу до небезпечних API**. Це ускладнює використання прихованих каналів для злоумисників.

ДР-3 — Використання ресурсів

Ця послуга обмежує користувачам доступ до ресурсів системи та дозволяє контролювати **споживання**. У Windows Server використовуються **GPO для призначення прав користувачам, Resmon, Task Scheduler та NTFS/Share Permissions**. Це дозволяє забезпечити контроль і запобігти захопленню ресурсів.

ДС-2 — Стійкість до відмов

Передбачає забезпечення працездатності системи навіть при виході з ладу окремих **компонентів**. Windows Server підтримує **автоматичне перезавантаження служб, моніторинг**

працездатності, а у редакціях Datacenter — **Failover Clustering**. Це дозволяє системі залишатися функціональною без повного відключення.

ДЗ-2 — Гаряча заміна

Дає змогу замінювати або оновлювати елементи системи без зупинки її роботи.

У Windows Server це досягається за допомогою **гарячої заміни дисків у RAID, Plug-and-Play драйверів та оновлень через WSUS або PowerShell без перезавантаження**. Такі дії мінімізують простой.

ДВ-2 — Відновлення після збоїв

Спрямована на повернення системи до робочого стану після збою. У Windows Server доступні інструменти: **Windows Server Backup, Volume Shadow Copy, System Restore**, а також **резервне копіювання через PowerShell/Task Scheduler**. Це забезпечує швидке відновлення працездатності.

НР-4 — Реєстрація

Ця послуга відповідає за фіксацію подій безпеки для подальшого аналізу. У Windows Server вона реалізується через **Audit Policies, Event Viewer, Windows Event Forwarding** та додаткові засоби, як-от **Sysmon**. Такий аудит дозволяє виявити й відслідковувати підозрілі дії.

НИ-2 — Ідентифікація і автентифікація

Забезпечує перевірку особистості користувача до надання доступу до системи. У Windows Server ця послуга реалізується через **Active Directory, Kerberos, політики паролів**, а також **двофакторну автентифікацію (Smart Card)**. Це унеможливорює анонімний або фальшивий вхід.

НК-1 — Достовірний канал

Гарантує безпечний та автентичний обмін службовими даними між компонентами.

У Windows Server використовуються **IPSec, TLS/SSL, SMB Signing**, а також **Kerberos** для **внутрішньої автентифікації**. Це мінімізує ризики перехоплення чи модифікації даних під час передачі.

НО-3 — Розподіл обов'язків

Спрямована на запобігання концентрації повноважень в одного користувача.

У Windows Server це реалізується через **групи безпеки AD, RBAC, делегування окремих прав адміністрування**, що дозволяє розділити повноваження між кількома особами. Це важливо для контролю та запобігання зловживанням.

НЦ-3 — Цілісність КЗЗ

Забезпечує цілісність конфігураційних файлів, налаштувань і механізмів захисту.

У Windows Server її реалізують **Integrity Monitoring, Digital Signatures, Device Guard**, а також сторонні SIEM-системи. Це дозволяє своєчасно виявити або заблокувати модифікації критичних налаштувань.

НТ-2 — Самотестування

Відповідає за автоматичну перевірку працездатності захисних механізмів.

У Windows Server ця функція реалізується через **вбудовані health-чеки, Windows Defender Health Monitor, планувальник завдань для діагностичних скриптів**, а також повідомлення в **Event Viewer**. Це забезпечує постійний контроль стану безпеки.

Висновки:

У ході роботи було обґрунтовано вибір профілю захищеності 2.КД.3, який відповідає класу і підкласу автоматизованої системи підприємства, що

проектує та обслуговує БПЛА. Цей профіль охоплює критично важливі послуги безпеки, зокрема конфіденційність, цілісність, доступність і спостережність. Встановлено, що середовище Windows Server забезпечує достатній набір вбудованих механізмів для реалізації кожної з послуг безпеки, таких як Active Directory, групові політики, BitLocker, аудит подій, резервне копіювання та засоби автентифікації. Для кожної послуги було запропоновано доцільні методи реалізації, які відповідають як вимогам стандарту НД ТЗІ 2.5-005-99, так і практичним потребам підприємства. Обраний підхід дозволяє забезпечити надійний рівень захисту інформації відповідно до визначених загроз та цілей системи.